

1 Bezpečnost informací

V dnešní době, kdy platí, že informace mají cenu zlata, neexistuje organizace (ať už se jedná o komerční subjekt nebo orgán veřejné správy), která by nějakými důležitými informacemi nedisponovala. Mohou to být informace z oblasti technického know-how, obchodní informace nebo jen osobní údaje zaměstnanců. Jedno však mají společné – je nutné je chránit. Není těžké si představit, co se může stát, pokud důležité informace (např. databáze klientů) budou nenávratně zničeny, nebo bude originální výrobní postup zaměstnancem vyžrazen konkurencí. Bezpečnost informací se zabývá právě způsoby zajištění takové ochrany.

Bezpečnost informací si klade za cíl chránit informace v jakékoliv podobě. Je zcela nepodstatné, jakou mají formu (listinnou nebo elektronickou), kde se uchovávají (zda-li v trezoru nebo ve vzdáleném informačním systému). To co je podstatné, je hodnota chráněných informací, případně velikost škody vzniklé v souvislosti s „poškozením“ těchto informací.

Je dobré si uvědomit, že ačkoliv zajištění bezpečnosti informací představuje vynaložení určitých nákladů, nejedná se o investici, která žádný přímý užitek nepřináší a pouze zatěžuje rozpočet. Ve skutečnosti lze přínos bezpečnosti informací ocenit právě výší škod, které by mohly nastat, pokud bychom bezpečnost informací neřešili. Je samozřejmě logické požadovat, aby cena za řešení nepřevyšovala hodnotu informací.

V dnešní době již nemusí řešení bezpečnosti informací (alespoň na první pohled) představovat problém. K dispozici je řada standardů či doporučení pro řešení bezpečnosti informací, existují kritéria, podle kterých lze úspěšnost vlastního řešení hodnotit, na trhu se pohybuje řada konzultantských společností, které jsou schopny se zajištěním ochrany informací pomoci. Přesto je však dobré vědět, co v dané oblasti existuje a s čím je možné se setkat a na co si dát pozor.

1.1 Historie a vývoj

Historie ochrany informací je stará jako lidstvo samo, neboť jakákoliv důležitá informace dostupná pro vyhrazenou skupinu lidí je pochopitelně důležitá i pro ty, kterým dostupná není. V historické době se proto ochrana informací soustřeďovala především na zajištění důvěrnosti – tedy ochranu před vyžrazením informací neoprávněným subjektům. Poměrně propracovaný systém měla ochrana informací státní povahy (utajované informace v armádě, diplomatická pošta apod.), v komerční sféře již tak dobrý stav nebyl. Na druhou stranu bylo (až na výjimky) jednoduché informace ve firmě chránit – ve většině případů postačil dostatečně odolný trezor.

S rozvojem informačních systémů se situace dramaticky změnila, neboť vzhledem ke své povaze mohou být elektronická data lehce kopírována, měněna či mazána a není ani nutné být přímo v místě jejich uložení. S nástupem moderních informačních technologií umožňujících uchovávání velkého množství informací o různé hodnotě se proto z ochrany informací stala disciplína postavená na pevných základech. Dnes již bezpečnost informací představuje poměrně rozsáhlý obor, který se stal nedílnou součástí studia v oblasti informačních systémů a s rostoucím objemem zpracovávaných dat stále více roste i jeho důležitost.

Určitým mezníkem jsou 80. léta minulého století, kdy byly vypracovány zásady ochrany informačních systémů – známá oranžová kniha (standard TCSEC), která byla následována dalšími standardy (ITSEC, CC, atd.). V 90. letech k tomuto trendu, který se zabývá především technickou stránkou věci, přistupují standardy zabývající se bezpečností IS zasazených do určitého prostředí a umožňující dosažení určitého stupně bezpečnosti bez složitých technických procedur – jedná se o standardy jako např. ISO/IEC TR 13335, řada BS 7799 apod.

Všechny tyto standardy či doporučení mají jedno společné – propracovaný přístup k řešení bezpečnosti informací založený na postupech, které jsou jednak výsledkem teoretických bádání, jednak obsahují zkušenosti posledních desetiletí z tohoto oboru. Tyto postupy mimo jiné zahrnují:

- Pečlivou analýzu informačního prostředí organizace (kde jsou informace uloženy, kudy putují, kdo s nimi a jak nakládá atd.),
- Analýzu bezpečnostních rizik, která dokumentuje hrozby vůči aktivům (aktivem je myšleno cokoliv, co má pro danou organizaci nějakou hodnotu – tedy i informace), zranitelnosti prostředí, v němž se aktiva nacházejí, a určuje výši rizika vzniku škody v případě, že by aktivum nebylo chráněno
- Výběr bezpečnostních opatření, která zamezují realizaci hrozby (opatření se vybírají s ohledem na výši rizika tak, aby cena opatření nepřevýšila škodu spojenou s uplatněním hrozby)
- Implementaci vybraných opatření
- Zavedení procedur, které podporují uplatnění vybraných opatření
- Tvorbu odpovídající bezpečnostní dokumentace (bezpečnostní politiky, bezpečnostní směrnice a příručky, havarijní plány a plány obnovy činnosti, ...)

Už jen z výčtu základních kroků je zřejmé, že zavedení bezpečnosti informací není jednoduchá záležitost, pokud navíc (což by mělo být samozřejmé) požadujeme, aby takto (a často i draze) implementovaný systém nezůstal jen na papíře, ale aby byl funkční. Jde o proces, který může být nad síly samotné organizace a je dobré se spojit s experty, kteří tuto oblast znají a jsou schopni splnit (ve spolupráci s organizací) požadavky na funkční systém ochrany informací kladené.

1.2 Důvody pro řešení bezpečnosti informací

Především si je nutné uvědomit, že v každé organizaci se vyskytují informace, které je potřeba chránit (přínejmenším osobní data zaměstnanců, neboť to ukládají zákony). K problému bezpečnosti těchto informací pak lze přistoupit dvojím způsobem:

- Můžeme se poohlédnout, co vše se nabízí, vybrat ten nejlepší firewall, nejlepší autentizační prostředky, nejlepší kamerový systém atd., atd., a to vše ve firmě instalovat či zavést a usínat s vědomím, že jsme pro svou firmu udělali maximum. V lepším případě „pouze“ zaplatíme daleko víc, než bylo nutné, v tom horším pak máme firmu přecpanou izolovanými bezpečnostními opatřeními, které chrání každé jen svoji oblast, nejsou provázána a není jasné, zda jsme na něco nezapomněli.
- Druhá možnost spočívá v tom, že se budeme držet vhodného standardu, vytýčíme si v oblasti bezpečnosti informací určité cíle a ty se systematicky budeme snažit naplnit při použití osvědčených postupů a doporučení. Výsledkem je pak řešení bezpečnosti informací, které je přiměřené hodnotám, které mají být chráněny a dokumentováno

takovým způsobem, že není problém při změně situace provést i změnu v systému ochrany informací.

Odsud plyne, že optimální řešení spočívá v použití osvědčených praktik, které dovolují nejen relativně bezproblémové zavedení bezpečnosti, ale také její řízení, monitorování a zlepšování. Takové řešení má pak nárok i na to, aby bylo porovnáno s požadavky použitého standardu a pokud je splní, může být certifikováno nezávislým certifikačním orgánem.

1.3 Koho by měla bezpečnost informací zajímat

Dosažení potřebné úrovně bezpečnosti informací v organizaci je především závislé na vůli managementu. Jako všechna restriktivní opatření i ta bezpečnostní mají více či méně obtěžující charakter a od zaměstnanců je vyžadováno plnění povinností navíc. Pokud tedy má být řešení bezpečnosti účinné, je nezbytné následující:

- Vedení organizace musí být srozuměno s nutností zavedení, udržování, monitorování a zlepšování bezpečnosti
- Vedoucí pracovníci musí vyžadovat od svých podřízených plnění povinností ve vztahu k bezpečnosti informací
- Podřízení musí mít možnost (tedy vědomosti a prostředky) povinnosti plnit

Z uvedeného je zřejmé, že bezpečnost informací (resp. procesy s ní spojené) zasahují všechny složky organizace až na úroveň jednotlivých pracovníků a nelze si proto myslet, že bezpečnost informací je záležitostí pouze bezpečnostního manažera.

1.4 Hlavní oblasti

Při vlastním řešení bezpečnosti informací záleží především na tom, v jakém měřítku chceme ochranu informací zajistit:

- Zdali je naším cílem řešit bezpečnost v rámci nějakého informačního systému
- Nebo chceme zajistit ochranu informací v celé organizaci

Ačkoliv principy i základní kroky jsou obdobné, vlastní provedení se může lišit.

V případě, že se jedná o relativně malou organizaci s informačním systémem, který slouží výhradně pro interní potřeby organizace (účetní systém, systém zajišťující výhradně přístup do internetu či k e-mailovým schránkám), je dostačující řešení bezpečnosti informací na úrovni organizace, které samozřejmě řeší i bezpečnost uvedeného IS. Výhodou je bezpečnostní řešení zahrnující vše podstatné v organizaci, s daleko jednodušší předpisovou základnou, než je tomu u organizací využívajících několik informačních systémů s různými požadavky na bezpečnost.

V případě organizací větších je nezbytné řešení rozdělit na ochranu informací v rámci procesů zahrnujících svou působností celou organizaci a na ochranu informací v jednotlivých informačních systémech. Tento postup je nezbytný vzhledem k tomu, že již nebývá možné (už jen z toho důvodu, že se v rámci organizace vyskytuje několik desítek či stovek rolí, kdy na každou z nich jsou kladeny jiné nároky) řešit bezpečnost informací v jedné rovině a je nezbytné hierarchické řešení. Skutečnosti společné celé organizaci jsou pak řešeny v té

nejvyšší rovině a řešení např. bezpečnosti informačních systémů je o patro níže. Tím je zajištěno, že i povinnosti budou diferencovány v závislosti na zastávané roli a stejně tak může být rozdělena i předpisová základna. Pochopitelně nastavení odpovídajícího modelu řešení ochrany informací již vyžaduje zkušenosti jak problematiky bezpečnosti informací, tak i vnitřních procesů organizace a zpravidla jedinou spolehlivou cestou k dosažení funkční ochrany informací pak je spolupráce s odbornou firmou.

Jednou z oblastí řešení ochrany informací při tomto členění je řešení bezpečnosti informačních systémů. Při jeho oddělení od obecného řešení ochrany informací organizace lze v daleko větší míře detailu postihnout jeho (především technologická) specifika a učinit tak IS daleko méně zranitelný.

1.5 Certifikace bezpečnosti informací

Pokud chce mít organizace jistotu, že pro bezpečnost svých informací udělala maximum, může si nechat provést bezpečnostní audit nezávislou společností. Jen tak se předejde velmi častým případům zanedbání některých oblastí, jejich podcenění nebo pouze formálnímu řešení. Další možností pak je dobrovolná certifikace podle standardu ISO 27001 (dříve BS 7799-2).

Co může standardizace přinést certifikované organizaci? Je to následující:

- Posouzení systému bezpečnosti informací a jejího řízení nezávislou akreditovanou autoritou
- Bezpečnost informací na garantované úrovni, takže není třeba spolupracujícím partnerům dokazovat svou úroveň ochrany informací
- Jistotu, že pro bezpečnost svých informací udělali maximum

Pokud je daná organizace certifikována podle ISO 9000 a/nebo ISO 14000, může s výhodou propojit své systémy řízení podle těchto standardů se systémem řízení bezpečnosti informací, všechny tři standardy totiž používají stejný model, takže navýšení prostředků na řízení další oblasti není tak velké.

1.6 Co jsou standardy v bezpečnosti informací

Standardy v oblasti bezpečnosti informací se zabývají nastavením, řízením a posuzováním bezpečnosti informací. Lze je rozdělit na několik skupin podle zaměření (i když hranice tohoto rozdělení nejsou vždy zcela ostré):

- Standardy v oblasti řízení bezpečnosti informací (BS 7799-2, ISO/IEC 27001, ISO/IEC TR 13335 – poslední norma je zaměřená především na IT)
- Osvědčené bezpečnostní praktiky (BS 7799-1, ISO/IEC 17799)
- Standardy pro posuzování bezpečnostních vlastností jednotlivých komponent IS (např. ISO/IEC 15408)

V zásadě lze říci, že manažery by měly zajímat první dvě oblasti, třetí oblast je určena pro organizace vyvíjející komponenty pro ICT, nebo architektky speciálně zaměřených IS (např. vojenských).

1.7 Historie a vývoj

80- léta	Velká Británie: Založení Commercial Computer Security Center (CCSC). CCSC a první výsledky jeho činnosti na poli bezpečnosti informací: - Vytvoření mezinárodně uznávaného souboru pravidel k hodnocení bezpečnostních kritérií včetně certifikačního schématu pro produkty s bezpečnostním aspektem (základ pro ITSEC). - Využití dlouholetých zkušeností britských organizací a vydání sbírky praktických bezpečnostních opatření - „Users Code of Practice“ v roce 1989.
1995	Po dalších úpravách a doplněních byla tato sbírka zveřejněna jako „British Standard's guidance“ dokument PD 0003 s pracovním názvem „A code of practice for information security management“, a posléze jako standard BS 7799:1995.
1998	Druhá část BS7799-2:1998 zabývající se řízením bezpečnosti informací byla připojena v únoru 1998.
1999	Po rozsáhlém přepracování byla v roce 1999 zveřejněna první revize první části jako BS 7799:1999
1999 2000	-První část BS 7799 byla v roce 1999 navržena na standard ISO a následně v prosinci 2000 publikována norma ISO/IEC 17799:2000.
2002	Po přepracování byla zveřejněna revize druhé části BS 7799-2:2002
2005	Zveřejnění normy ISO/IEC 17799:2005.
2005	Je zveřejněna norma ISO/IEC 27001, obsahuje určité změny oproti BS7799-2:2002.

1.8 Kdo by měl používat standardy bezpečnosti informací

Jako i v jiných oblastech lze k řešení problematiky přistoupit dvojím způsobem:

- můžeme si bezpečnost informací řešit sami
- můžeme řešení bezpečnosti informací ponechat na externím subjektu

a jako i jindy, nejlepší bývá střední cesta: vedení organizace by mělo zvážit potřebu zavedení bezpečnosti, ve spolupráci s experty v dané oblasti bezpečnost zavést, a dále ji řídit a vylepšovat, pokud možno pod dohledem zkušených odborníků. Odsud plyne, že principy standardů musí být jasné minimálně těm, kdo po zavedení budou tuto oblast řídit – tedy bezpečnostním manažerům.

Zdroj: <http://www.ital.cz>

1.9 Přehled standardů

- Pro řešení bezpečnosti informací v organizaci (kde kromě elektronických nosičů informací se vyskytují i neelektronické (listinné) podoby a je tedy nutné podchytit všechny formy informací, je nejvhodnějším standardem pro oblast řízení bezpečnosti standard ISO/IEC 27001 a pro praktické zavedení pak ISO/IEC 17799.
- Pokud chceme „pouze“ řešit bezpečnost konkrétního informačního systému, lze opět použít standardy výše uvedené, nebo použít standard ISO/IEC TR 13335, případně (ale to již s pomocí znalých odborníků) se obrátit např. k standardu ITSEC nebo ISO/IEC 15408 (známý také pod názvem Common Criteria).

1.9.1 Mezinárodní normy ISMS řady ISO/IEC 27xxx přijaté a vydané Úřad pro technickou normalizaci, metrologii a státní zkušebnictví v českém jazyce

ČSN ISO/IEC 27000:2010

Informační technologie - Bezpečnostní techniky - Systémy řízení bezpečnosti informací - Přehled a slovník

ČSN ISO/IEC 27001:2006

Informační technologie - Bezpečnostní techniky - Systémy managementu bezpečnosti informací – Požadavky

ČSN ISO/IEC 17799:2006 (oprava označení na ISO/IEC 27002 vydána UNMZ v roce 2008)

Informační technologie - Bezpečnostní techniky - Soubor postupů pro management bezpečnosti informací

ČSN ISO/IEC 27004:2011

Informační technologie - Bezpečnostní techniky - Řízení bezpečnosti informací - Měření

ČSN ISO/IEC 27005:2009

Informační technologie - Bezpečnostní techniky - Řízení rizik bezpečnosti informací

ČSN ISO/IEC 27006:2008

Informační technologie - Bezpečnostní techniky - Požadavky na orgány provádějící audit a certifikaci systémů řízení bezpečnosti informací

ČSN EN ISO 27799:2010

Zdravotnická informatika - Systémy řízení bezpečnosti informací ve zdravotnictví využívající ISO/IEC 27002

1.9.2 Další normy vydané v angličtině

ISO/IEC 27011:2008

Information technology — Security techniques — Information security management guidelines for telecommunications organizations based on ISO/IEC 27002

ISO/IEC 27031:2011

Information technology — Security techniques — Guidelines for information and communications technology readiness for business continuity

ISO/IEC 27033-1:2009

Information technology — Security techniques — Network security overview and concepts

ISO/IEC 27035:2011

Information technology — Security techniques — Information security incident management

Zdroje: <https://www.technickenormy.cz>

1.9.3 Standardy používané v USA**Federal Information Security Management Act of 2002 („FISMA“)**

Federální zákon o managementu bezpečnosti informací. Vyžaduje, aby každý federální úřad zavedl program bezpečnosti informací a informačních systémů, včetně služeb poskytovaných nebo řízených jiným úřadem nebo dodavatelem.

FIPS (Federal Information processing standard)PUB 199

Standardy pro kategorizaci bezpečnosti federálních informací a informačních systémů

FIPS PUB 200

Minimální požadavky na bezpečnost federálních informací a informačních systémů

NIST Special Publications 800 series (NIST SP 800 series)

Příručky pro posuzování, výběr a implementaci bezpečnostních opatření v informačních systémech a ICT technologiích

Zdroje: <https://csrc.nist.gov/publications/sp>

1.9.4 Standardy používané ve Spolkové republice Německo

BSI Standard 100-1: Information Security Management Systems (ISMS)

BSI-Standard 100-2: IT-Grundschutz Methodology

BSI-Standard 100-3: Risk Analysis based on IT-Grundschutz

BSI-Standard 100-4: Business Continuity Management

Zdroje: https://www.bsi.bund.de/EN/Home/home_node.html

1.9.5 NIS2

NIS2 je modernizovaná verze směrnice NIS z roku 2016. Jejím cílem je posílit a zabezpečit evropský kyberprostor. Členské státy EU mají povinnost implementovat tuto směrnici do svého právního systému. NIS2 přináší nová opatření pro zlepšení kybernetické bezpečnosti.

- Nový Zákon o kybernetické bezpečnosti implementuje požadavky směrnice NIS2 do českého právního řádu.
- Pro společnosti je klíčové, zda spadají pod nižší nebo vyšší režim. Od toho se odvíjí jejich povinnosti.

Navržený nový Zákon o kybernetické bezpečnosti má nahradit současný zákon z roku 2014. Návrh nového zákona přináší tyto klíčové změny:

- Regulované organizace a služby: Nový zákon se týká nově regulovaných subjektů a zároveň upravuje působnost na další systémy a služby organizací, které již podléhají stávajícímu kybernetickému zákonu.
- Bezpečnost dodavatelského řetězce: Nový ZoKB klade větší důraz na bezpečnost dodavatelského řetězce.
- Hlášení incidentů: Regulované subjekty budou mít povinnost hlásit kybernetické incidenty.
- Pokuty: Maximální výše pokuty za porušení povinností zákona může činit 250 mil. Kč nebo 2 % z čistého celosvětového ročního obrátu.
- Odpovědnost a povinnosti vedení: Zákon zdůrazňuje odpovědnost a povinnosti vrcholného vedení organizací.

Směrnice NIS2 byla na úrovni EU přijata v prosinci 2022. Návrh zákona byl 17. července 2024 schválen vládou. Účinnost nové regulace se předpokládá k 1. lednu 2025. K plnění některých povinností, jako například zavádění bezpečnostních opatření, zákon stanovuje roční přechodovou lhůtu.

NIS2 respektive nový Zákon o kybernetické bezpečnosti dopadne v Česku přibližně na 6 000 organizací oproti stávajícím 300. Zákon bude regulovat přes 105 služeb v 18 odvětvích. Hlavními kritérii pro určení, jestli organizace spadá pod povinnosti nového Zákona, jsou její velikost (počet zaměstnanců nebo obrát) a služby, které poskytuje (alespoň jednu tzv. regulovanou službu).

Zákon rozděluje poskytovatele regulované služby, kteří naplní daná kritéria, do dvou kategorií – režimu nižších a vyšších povinností.

Oproti původní směrnici NIS a Zákonu o kybernetické bezpečnosti významně naroste počet regulovaných subjektů. Zvyšují se také sankce z původních 5 milionů Kč na 250 mil. Kč (nebo 2 % celosvětového ročního obrátu) a přibýly také nefinanční sankce jako pozastavení certifikace nebo pozastavení výkonu řídicí funkce vrcholného managementu. Mezi nejvýznamnější změny v povinnostech patří:

- zodpovědnost vrcholného managementu za řízení kybernetické bezpečnosti,
- nutnost kontinuálního zvyšování bezpečnostního povědomí,
- potřeba identifikovat a evidovat aktiva (u vyššího režimu pak ještě povinnost identifikovat a hodnotit rizika),
- zavedení minimálních (smluvních i bezpečnostních) požadavků na dodavatele.

Organizace musí samy posoudit, jestli splňují podmínky pro registraci regulované služby a tedy vztahují se na ně povinnosti nového Zákona. Může jim k tomu pomoci Vyhláška o regulovaných službách anebo náš webový rozcestník. Pokud společnost podmínky naplňuje, musí se ohlásit u Národního úřadu pro kybernetickou a informační bezpečnost prostřednictvím jejich platformy Portál NÚKIB. Následně musí stanovit systém řízení kybernetické bezpečnosti dle rozsahu povinností, které se liší podle toho, zda regulovaná služba spadá do vyššího nebo nižšího režimu povinností.

2 Definice pojmů bezpečnosti informací

Zde se seznámíme se základními a často používanými pojmy bezpečnosti informací, na jejichž významu a obsahu se nezdá nedokáže shodnout ani odborná veřejnost.

2.1 Základní pojmy

Aktivum (Asset) je cokoliv, co má pro organizaci hodnotu.

Bezpečnost informací (Information security) je ochrana důvěrnosti, integrity a dostupnosti informací.

Dostupnost (Availability) je zajištění toho, že informace a s nimi spojená aktiva jsou uživatelům přístupná v době, kdy je požadují.

Dopad (Impact) je výsledek nežádoucího incidentu.

Důvěrnost (Confidentiality) je zajištění toho, že informace je přístupná jen těm, kteří jsou oprávněni k ní mít přístup.

Hodnocení rizik (Risk assessment) je posouzení pravděpodobnosti selhání bezpečnosti, které by se mohlo vyskytnout působením hrozeb a zranitelností a dopady na konkrétní aktiva.

Hodnocení aktiv (Asset assessment) je stanovení hodnoty aktiva v závislosti na posouzení dopadů na činnost organizace, které by mohly vyplynout ztráty důvěrnosti, integrity nebo dostupnosti aktiv.

Hrozba (Threat) je potenciální příčina nežádoucího incidentu, který může mít za následek poškození systému nebo organizace.

Identifikace aktiva (Asset identification) je proces, který předchází vytvoření seznamu aktiv a určení vlastníka daného aktiva.

Informace (informační aktiva) jsou výsledné, tj. vybrané či jinak zpracované údaje (data), prezentované ve formě snadno čitelné, pochopitelné a využitelné subjektem, jemuž jsou určeny. Mohou být v elektronické formě nebo napsané (vytištěné) v listinné formě, vyřčené při jednání nebo zaznamenané na jiném médiu.

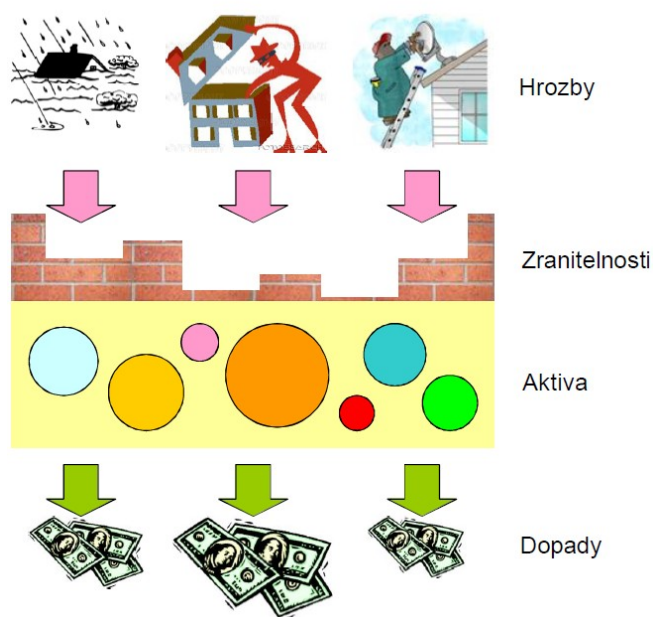
Integrita (Integrity) je zabezpečení přesnosti a kompletnosti informace a metod jejího zpracování.

Riziko (Risk) je potenciální možnost, že daná hrozba způsobí poškození nebo zničení aktiv.

Redukované riziko je riziko, kterému bude organizace čelit po implementaci všech opatření pro snížení rizik, vyplývajících z analýzy rizik.

Vlastník aktiva je jednotlivec, jemuž byla vedením přidělena odpovědnost za produkci, vývoj, údržbu, použití a bezpečnost aktiv; neznamena to však, že by byl jejich skutečným vlastníkem a měl k nim vlastnická práva.

Zranitelnost (Vulnerability) je slabé místo aktiva nebo skupiny aktiv, které může být využito jednou nebo více hrozbami.

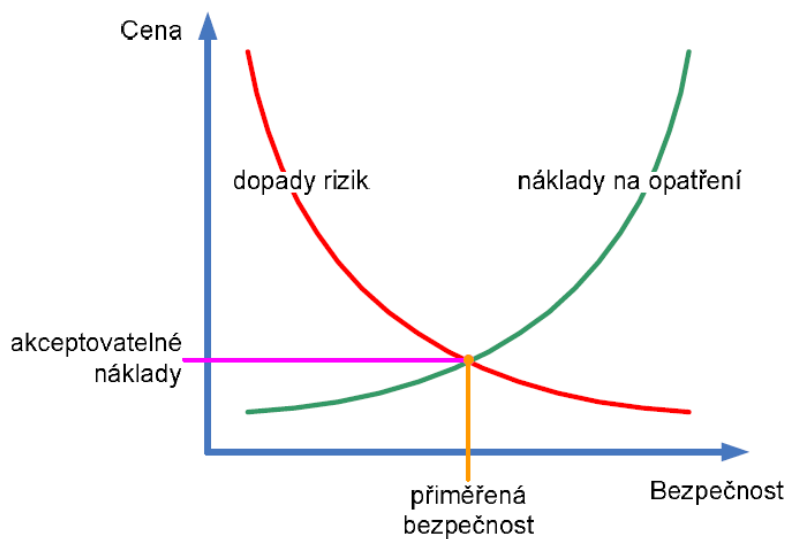


Základní pojmy bezpečnosti informací

2.2 Přiměřená úroveň bezpečnosti

Zajištění bezpečnosti není hledáním dokonalého způsobu ochrany, ale aplikací takových opatření, která jsou přiměřená hodnotě předmětu ochrany (aktiv).

Primárním předmětem ochrany jsou informace (nikoliv jejich nosiče nebo prostředky pro zpracování). Čím větší hodnotu pro nás informace mají, tím větší pozornost musíme věnovat bezpečnosti jejich nosičů. Každá organizace by si proto měla provádět alespoň základní hodnocení a kategorizaci svých informací a tomu přizpůsobit i způsob jejich ochrany.



Zvažování rizik a opatření (analýza nákladů a přínosů)

Velikost úsilí a investic do bezpečnosti musí odpovídat hodnotě aktiv a míře možných rizik. Změny v procesech organizace při zavádění standardů řízení bezpečnosti a při aplikaci opatření v ICT systémech musí dostatečně redukovat dopady možných rizik za akceptovatelných nákladů.

Zdroj: <http://www.cybersecurity.cz/data/Gogela.pdf>